

Authentication, Passwords & MFA

Authentication = Who You Claim to Be + Proof

Three factors:

Something you know – password, PIN

Something you have – phone, hardware key

Something you are – fingerprint, face, iris

Why Passwords Are Broken

Humans reuse them ("password", "123456")

Breaches leak them by the millions

They can be guessed, phished, sniffed, keylogged

Solution stack: password managers + MFA + biometrics + passkeys. And never reuse.

Password Storage Done Right

Servers must NEVER store plaintext or reversible-encrypted passwords. They store:

Hash – one-way (SHA-256 style)

Salted + slowed – bcrypt/argon2/scrypt with a random per-user salt

```
# password hash with salt via htpasswd (bcrypt)
htpasswd -bnBC 10 "" "MyPass123" | tr -d ':\n'
# $2y$10$<salt...>$<bcrypt hash>
```

The salt defeats rainbow tables; the "cost" factor (slowness) defeats GPU cracking.

Offline Password Cracking

An attacker with the hash can crack offline at millions of guesses/sec:

- Dictionary attack – common words
- Brute force – all combinations
- Rule-based – "password1!", "p@ssw0rd"
- Rainbow tables – precomputed hash chains (defeated by salt)

Known tooling: hashcat, John the Ripper. *Determining the hash type (e.g., \$2y\$ = bcrypt, \$6\$ = sha512crypt, NTLM = 32 hex) is half the battle.*

MFA Methods & Their Weaknesses

Factor	Strength	Attack
SMS codes	Weak	SIM swap, SMS interception, phishing forwards
TOTP app (Google Auth/Authy)	Medium	Phishing (MFA fatigue, real-time relay)
Push notification	Medium	"MFA fatigue" prompts – user approves anyway
Hardware key (YubiKey)	Strong	Needs physical possession; very hard to phish
Passkeys (WebAuthn)	Strong	Resistant to MITM phishing

Best Practice Authentication Stack

- Password manager for unique random passwords
- Phishing-resistant MFA (hardware key/passkeys) for critical accounts
- Never SMS if avoidable
- Enforce (and educate): no hint, no reuse
- On the service side: lockout/wait after repeated failures (throttling defeats online brute force)

[← Windows Security & Active Di...](#)

[Linux & Windows Hardening →](#)